Lab-09: Design and Test a Detection Rule

Course: Cyber Security Awareness Workshop

Course code: C506

Time: 30 minutes

Alignment: LO3

Tool: [Regex Generator](https://alfredang.github.io/regexgenerator/)

Scenario

A security team needs a transparent rule for repeated failed logins and suspicious usernames.

Safety and authorisation boundary

- Use only the named training tool and the mock files in this folder.
- Do not enter real passwords, personal data, payment details or confidential information.
- Do not test any other website, network, account or organisation.
- Stop immediately if the target, data or behaviour differs from the written scope.
- Prefer reversible actions and preserve synthetic evidence.

Mock data

- `mock-auth.log`
- `mock-detection-requirements.csv`

Detailed procedure

1. Read the detection requirements and label the supplied log lines as expected match or expected non-match.

2. Use Regex Generator to build a pattern for failed-login lines while capturing timestamp, username and source IP.

3. Test every line and calculate true positives, false positives and false negatives.

4. Refine the expression to reduce noise without excluding the malicious samples.

5. Define a threshold and time window for escalation; explain the cost of a threshold that is too low or too high.

6. Document the rule purpose, assumptions, limitations, owner and review date.

Completion standard

- Tested regex
- Confusion matrix
- Threshold decision
- Rule documentation
- Escalation criteria

Reflection

What evidence would make you reverse your decision, and who would need to know?